

**UNIVERSIDAD PRIVADA DE TACNA
FACULTAD DE INGENIERÍA
ESCUELA DE INGENIERÍA DE SISTEMAS**



TALLER

“Auditoría de Seguridad Web Externa basada en OWASP”

CURSO:

“AUDITORÍA DE SISTEMAS”

AUTOR(ES):

Gabriela Luzkalid Gutierrez Mamani	2022074263
Mayra Fernanda Chire Ramos	2021072620
Sebastián Nicolas Fuentes Avalos	2022073902

DOCENTE:

DR. OSCAR JUAN JIMENEZ FLORES

**TACNA — PERÚ
2026**

Auditoría de seguridad web externa de tecnologías de la información al Banco Internacional del Perú – Interbank

Ubicación de referencia: Lima, Perú, según el caso proporcionado.

Materia de control: seguridad del portal público <https://interbank.pe> frente a amenazas accesibles desde Internet.

Lugar y fecha de aprobación: Lima, 7 de octubre de 2026.

Periodo de ejecución previsto: 12 de octubre al 6 de noviembre de 2026.

Versión: 1.0, propuesta académica.

Estado: versión final para exposición académica; no acredita encargo, autorización para pruebas ni hallazgos confirmados.



ÍNDICE

I. ORIGEN.....	4
II. INFORMACIÓN DE LA ENTIDAD O DEPENDENCIA.....	4
III. DENOMINACIÓN DE LA MATERIA DE CONTROL	5
IV. ALCANCE.....	5
IV.1 Delimitación.....	5
IV.2 Condiciones previas y reglas de ejecución	5
IV.3 Limitaciones de interpretación	6
V. OBJETIVOS	6
Objetivo general	6
Objetivos específicos.....	6
VI. PROCEDIMIENTOS DE AUDITORÍA	7
VII. PLAZO DE LA AUDITORÍA Y CRONOGRAMA	9
VIII. CRITERIOS DE AUDITORÍA	9
IX. INFORMACIÓN ADMINISTRATIVA.....	10
IX.1 Comisión Auditora	10
IX.2 Costos Directos Estimados	11
X. DOCUMENTO A EMITIR.....	12
ANEXO 1. MATRIZ DE RIESGOS EN TI	12
ANEXO 2. MAPEO DE PROCESOS DE TI.....	13
ANEXO 3. LISTA DE CRITERIOS APLICABLES	14
ANEXO 4. INSTRUMENTOS DE RECOLECCIÓN DE EVIDENCIA	14
A4.1 Ficha de evidencia	15
A4.2 Guía breve de entrevistas y solicitud documental.....	15
A4.3 Lista de comprobación de calidad del hallazgo	15
ANEXO 5. MATRIZ DE TRAZABILIDAD	16
ANEXO 6. CRONOGRAMA DETALLADO POR ACTIVIDAD Y RESPONSABLE	16
Notas de preparación	¡Error! Marcador no definido.

I. ORIGEN

El caso académico plantea evaluar la exposición externa del portal público de Interbank y enumera **hipótesis preliminares**, sin evidencia técnica adjunta que permita tratarlas como hallazgos. Estas hipótesis comprenden encabezados HTTP, atributos de cookies, bibliotecas JavaScript, protección de formularios y redirecciones. La auditoría propuesta busca obtener evidencia reproducible, valorar el riesgo de cada debilidad confirmada y recomendar correcciones priorizadas.

El caso menciona OWASP Top 10 como marco de riesgos. Para convertir esos riesgos en pruebas y criterios concretos se adopta **OWASP Application Security Verification Standard (ASVS) v4.0.3, edición en español**, suministrado con el caso. ASVS distingue niveles L1, L2 y L3. Dado que se trata de una revisión externa sin credenciales ni código, este plan selecciona requisitos L1 observables desde el portal público; **no afirma cobertura completa ni conformidad ASVS L1**. Por tratarse de un banco y de servicios que podrían manejar datos sensibles, una evaluación posterior de mayor garantía debería considerar L2/L3 con acceso acordado a arquitectura, código, configuraciones, registros y cuentas de prueba (ASVS, pp. 11-14).

II. INFORMACIÓN DE LA ENTIDAD O DEPENDENCIA

Campo	Dato de planificación
Entidad	Banco Internacional del Perú - Interbank, según el caso.
Sector	Banca y finanzas, según el caso.
Nivel de gobierno	No aplica: entidad privada.
Sede de referencia	Lima, Perú, según el caso.
Activo focal	Sitio público https://interbank.pe .
Contraparte operativa del caso	Responsable de Seguridad de la Información y propietario técnico del portal; canal de coordinación definido en el acta de inicio simulada.

Los datos organizacionales del caso se usan para planificar, no como hechos verificados de la entidad.



III. DENOMINACIÓN DE LA MATERIA DE CONTROL

Gestión de la seguridad de la aplicación web pública y de su exposición externa, específicamente controles observables de transporte TLS, configuración HTTP, cookies emitidas en navegación pública, recursos de terceros, formularios y redirecciones del host autorizado.

IV. ALCANCE

IV.1 Delimitación

Dimensión	Incluido	Límite
Activo	Host interbank.pe y rutas públicas que la entidad identifique expresamente como propias.	La presencia de un enlace no incorpora automáticamente otro host, subdominio, CDN, proveedor o servicio de banca autenticada.
Perspectiva	Usuario externo sin autenticación; navegador y solicitudes de bajo impacto acordadas.	No se ingresará a cuentas ni se probarán roles de usuario.
Controles	TLS, respuesta HTTP, cookies visibles, recursos de cliente, entrada y salida de formularios públicos, destinos de redirección y exposición de errores.	Código fuente, controles internos, registros, infraestructura privada y eficacia de controles no observables.
Periodo revisado	Estado del activo durante la ventana de ejecución autorizada.	No se inferirá la seguridad histórica ni continua a partir de una captura puntual.
Muestreo	Portada y una muestra de rutas públicas representativas: productos, formularios y rutas de redirección, una vez acordadas.	Las conclusiones se limitarán a las rutas y momentos observados.

IV.2 Condiciones previas y reglas de ejecución

Para fines del caso, se asume un acta de autorización formal suscrita por la contraparte operativa, con inventario del host y rutas públicas, ventana de trabajo, contactos de emergencia, límites de frecuencia, direcciones IP de origen, tratamiento de datos y



procedimiento de suspensión. **Este documento académico no habilita pruebas contra sistemas reales.**

Las pruebas autorizadas se limitarán a solicitudes de bajo impacto y datos sintéticos. Se excluyen denegación de servicio, fuerza bruta, evasión de defensas, explotación persistente, carga de archivos peligrosos, extracción de datos, ingeniería social y pruebas de terceros sin permiso específico. Si una respuesta muestra datos de clientes o comportamiento anómalo, se detiene esa prueba, se conserva solo la evidencia mínima necesaria y se comunica por el canal acordado.

IV.3 Limitaciones de interpretación

- La ausencia visual de CAPTCHA **no demuestra** falta de controles anti-automatización; pueden existir límites, controles adaptativos u otras defensas.
- Un encabezado ausente o una cookie sin atributo se evalúan según su función, contexto y riesgo; no toda observación implica una vulnerabilidad explotable.
- La versión de una biblioteca inferida desde el cliente no prueba por sí sola que el componente desplegado sea vulnerable o que la ruta afectada sea alcanzable.
- Los controles de autenticación, autorización, sesiones autenticadas y lógica transaccional están fuera del alcance de esta revisión externa sin credenciales.
- La revisión externa no sustituye una verificación integral ASVS ni una certificación OWASP.

V. OBJETIVOS

Objetivo general

Determinar, con evidencia suficiente y reproducible, si los controles de seguridad observables del portal público reducen los riesgos de exposición externa definidos en el caso, y proponer acciones de mejora priorizadas.

Objetivos específicos

1. **O1 - Transporte y configuración:** evaluar TLS y encabezados HTTP de seguridad en una muestra de rutas públicas.
2. **O2 - Cliente y sesión pública:** examinar cookies accesibles sin autenticación, recursos de terceros y exposición de datos en navegador.
3. **O3 - Interacción pública:** evaluar, de forma controlada, validación de formularios, manejo de errores, redirecciones y defensas observables contra automatización.
4. **O4 - Gestión del riesgo:** documentar evidencia, causa probable, impacto, limitaciones y recomendaciones verificables para cada hallazgo confirmado.

**VI. PROCEDIMIENTOS DE AUDITORÍA**

Cuadro n.º 1 - Programa de procedimientos. Cada resultado se clasificará como *cumple en la muestra, no cumple o no aplicable*, con justificación. Los identificadores ASVS se expresan con versión, como recomienda el estándar (p. 13).

ID	Objetivo	Procedimiento y criterio principal	Evidencia esperada	Responsable
P 01	O1-O3	Confirmar autorización, inventario del host, rutas y flujos públicos; seleccionar muestra y registrar hora, URL, método y contexto.	Acta de alcance, matriz de rutas y registro de muestra.	Jefe de comisión
P 02	O1	Revisar certificados, negociación y versiones/cifrados TLS desde el exterior, con pruebas de bajo impacto. ASVS v4.0.3-9.1.1 a 9.1.3.	Configuración observada, fecha, herramienta/versión y capturas o salidas sanitizadas.	Especialista de infraestructura
P 03	O1	Revisar CSP, HSTS, nosniff, Referrer-Policy y protección contra incrustación en respuestas de la muestra; interpretar políticas efectivas, no solo presencia. ASVS v4.0.3-14.4.1, 14.4.3 a 14.4.7.	Encabezados completos por ruta, análisis de contexto y prueba de reproducción inocua.	Especialista AppSec
P 04	O2	Identificar cookies emitidas en páginas públicas y evaluar propósito, Secure, HttpOnly, SameSite, prefijo __Host-, dominio y ruta cuando sean cookies de sesión . ASVS v4.0.3-3.4.1 a 3.4.5.	Set-Cookie redactado, función inferida/confirmada y matriz de atributos.	Especialista AppSec
P 05	O2	Inventariar JavaScript/CSS de terceros y versiones visibles; revisar SRI cuando aplique y contrastar vulnerabilidades únicamente con identificación fiable y contexto de uso. ASVS v4.0.3-14.2.1 y 14.2.3.	Lista de recursos, origen, versión y sustento de relevancia.	Especialista AppSec
P 06	O3	En formularios públicos autorizados, revisar campos, límites y manejo de entradas con valores sintéticos benignos; observar reflejos y codificación de salida. ASVS v4.0.3-5.1.3, 5.1.4, 5.3.1 y 5.3.3.	Solicitud/respuesta sanitizada, validaciones observadas y contexto de salida.	Especialista AppSec



ID	Objetivo	Procedimiento y criterio principal	Evidencia esperada	Responsable
P 07	O3	Identificar parámetros de retorno o enlaces de transición del host permitido; validar destinos solo con redirecciones de prueba inocuas. ASVS v4.0.3-5.1.5.	Cadena de redirección y regla observada, sin visitar servicios ajenos al alcance.	Especialista AppSec
P 08	O3	Revisar controles anti-automatización visibles en formularios mediante evidencia documental y un volumen mínimo de pruebas establecido en el acta de inicio. ASVS v4.0.3-11.1.3 y 11.1.4.	Límite definido, respuesta observada y evidencia documental.	Jefe / AppSec
P 09	O2-O3	Examinar si páginas públicas o formularios exponen datos sensibles en URL, almacenamiento del navegador, caché o mensajes de error. ASVS v4.0.3-7.4.1, 8.2.1, 8.2.2 y 8.3.1.	Capturas sanitizadas, cabeceras de caché y mensajes observados.	Especialista AppSec
P 10	O1	Revisar divulgación innecesaria de versiones o modos de depuración en respuestas públicas. ASVS v4.0.3-14.3.2 y 14.3.3.	Respuestas sanitizadas por ruta.	Especialista de infraestructura
P 11	O4	Correlacionar cada observación con requisito, escenario de amenaza, impacto y probabilidad; descartar falsos positivos y solicitar contradicción técnica a la entidad.	Hojas de trabajo, matriz de hallazgos y respuestas de la entidad.	Jefe / Supervisor
P 12	O4	Preparar informe, plan de corrección y pruebas de verificación acordadas; validar que las conclusiones reflejan el alcance real.	Informe revisado y acta de cierre.	Jefe / Supervisor

Criterio de suficiencia: un hallazgo requiere activo y ruta, condición observada, criterio aplicable, evidencia fechada, efecto técnico plausible y revisión de explicaciones alternativas. Una sola herramienta o alerta automática no basta para declararlo. La clasificación de severidad combinará impacto sobre confidencialidad, integridad y disponibilidad con explotabilidad y exposición real. Las observaciones sin explotación demostrada se describirán con lenguaje proporcional.



VII. PLAZO DE LA AUDITORÍA Y CRONOGRAMA

Duración estimada: **20 días hábiles, del 12 de octubre al 6 de noviembre de 2026**, bajo el supuesto académico de que el acta de inicio y la información de alcance se entregan el primer día.

Etapa	Días hábiles relativos	Producto de control
Planificación	1-5	Acta de alcance, reglas de ejecución, inventario y muestra.
Ejecución	6-16	Papeles de trabajo, evidencias y observaciones preliminares.
Informe y cierre	17-20	Contradicción técnica, informe final y matriz de acciones.

Hitos de control: al cierre del día 5 se valida el alcance; durante la ejecución se comunica de inmediato cualquier riesgo crítico confirmado; el día 17 se remiten observaciones para comentario técnico; el día 20 se entrega el informe.

VIII. CRITERIOS DE AUDITORÍA

- 1. Criterio técnico principal:** OWASP ASVS v4.0.3 (es), requisitos seleccionados indicados en el cuadro n.º 1. La selección es focal y de observación externa; no constituye una evaluación íntegra del nivel L1.
- 2. Marco de priorización:** categorías de OWASP Top 10 mencionadas en el caso, usadas para ordenar riesgos, sin sustituir los requisitos concretos ASVS ni atribuir una edición no indicada en los insumos.
- 3. Criterios internos del caso:** política de seguridad de la información, estándar de desarrollo seguro, clasificación de información, gestión de cambios e incidentes consignados en el acta de inicio simulada. Estos criterios complementan, pero no reemplazan, ASVS.
- 4. Criterios legales y regulatorios:** el plan considera la protección de datos y la continuidad operacional como factores de impacto; no emite una opinión de cumplimiento regulatorio o contractual del banco.

La ausencia de evidencia para un requisito interno o no observable se registrará como limitación, nunca como incumplimiento automático. Los requisitos ASVS 4.0.3-3.4.x se aplican a **tokens de sesión basados en cookies**, por lo que no se extrapolarán sin análisis a cookies funcionales o analíticas.

IX. INFORMACIÓN ADMINISTRATIVA

IX.1 Comisión Auditora

Cuadro n.º 2 - Comisión auditora. La comisión está integrada por tres profesionales; los roles se acumulan de forma controlada, práctica usual en encargos de alcance acotado. La revisión de calidad de cada papel de trabajo es realizada por un integrante distinto de quien lo preparó. Las jornadas son de ocho horas y pueden solaparse dentro de los 20 días hábiles.

Cargo / función acumulada	Nombres y apellidos	Perfil académico/profesional propuesto	Planificación (días)	Ejecución (días)	Informe (días)	Total (días)
Jefa de comisión y especialista en seguridad de aplicaciones web	Gabriela Luzkalid Gutierrez Mamani	Formación en Ingeniería de Sistemas; planificación de auditoría, pruebas AppSec y gestión del riesgo.	4	9	4	17
Supervisora técnica y especialista en infraestructura web	Mayra Fernanda Chire Ramos	Formación en Ingeniería de Sistemas; revisión de calidad, TLS, HTTP y configuración externa.	4	8	4	16
Auditor de seguridad web y responsable de evidencias	Sebastian Nicolas Fuentes Avalos	Formación en Ingeniería de Sistemas; pruebas funcionales externas, trazabilidad y documentación de evidencias.	3	11	5	19
Total			11	28	13	52

La jefa de comisión aprueba el programa y el informe; la supervisora revisa la consistencia metodológica y los papeles preparados por los otros integrantes; el auditor responsable de evidencias custodia la trazabilidad. Esta segregación permite mantener control de calidad sin crear una cuarta plaza ni duplicar el presupuesto.

IX.2 Costos Directos Estimados

Cuadro n.º 3 - Costo de horas hombre y asignaciones. El costeo usa una jornada de ocho horas. La tarifa hora se obtiene dividiendo la remuneración mensual referencial entre 176 horas (22 días × 8 horas) y se redondea a dos decimales. Es un costo directo de personal para fines académicos, no una cotización comercial ni una remuneración atribuida a Interbank.

N.º	Miembro	Nivel	Días	Costo Total H/H (S/.)	Asignación (S/.)	Costo Total (S/.)	Pasajes	Viáticos
1	Gabriela Luzkalid Gutierrez Mamani — Jefa de comisión / AppSec	Especialista	17	4,841.60	0.00	4,841.60	0.00	0.00
2	Mayra Fernanda Chire Ramos — Supervisora técnica / infraestructura	Especialista	16	4,096.00	0.00	4,096.00	0.00	0.00
3	Sebastian Nicolas Fuentes Avalos — Auditor web / evidencias	Analista	19	3,886.64	0.00	3,886.64	0.00	0.00
	Total		52	12,824.24	0.00	12,824.24	0.00	0.00

Justificación de tarifas y gastos: Gabriela: 136 h × S/ 35.60; Mayra: 128 h × S/ 32.00; Sebastian: 152 h × S/ 25.57. Las tarifas se derivan de remuneraciones mensuales referenciales de S/ 6,264.19, S/ 5,628.00 y S/ 4,500.00, respectivamente. Los dos primeros referentes proceden de convocatorias públicas peruanas para analista TI y analista de herramientas de seguridad informática; el tercero se ubica en el punto medio del rango publicado de S/ 3,500 a S/ 5,000 para especialista en ciberseguridad en Lima. La asignación, pasajes y viáticos son S/ 0.00 porque el escenario contempla ejecución remota dentro de Lima y uso de herramientas de libre acceso o institucionales.

Costo directo total: S/ 12,824.24.

Elaborado por: Gabriela Luzkalid Gutierrez Mamani, Mayra Fernanda Chire Ramos y Sebastian Nicolas Fuentes Avalos.

X. DOCUMENTO A EMITIR

Se emitirá un **Informe de Auditoría de Seguridad Web Externa** que incluya resumen ejecutivo, alcance efectivo, criterios, metodología, limitaciones, hallazgos sustentados, severidad, riesgo residual, recomendaciones con prioridad y responsable propuesto, respuesta de la entidad, anexos de evidencia sanitizada y matriz de seguimiento. Cada conclusión consignará el procedimiento aplicado, el criterio utilizado y la evidencia que la sustenta. El documento no se presentará como certificación OWASP.

Lugar y fecha de suscripción: Lima, 7 de octubre de 2026.

Comisión auditora: Gabriela Luzkalid Gutierrez Mamani (jefa de comisión), Mayra Fernanda Chire Ramos (supervisora técnica) y Sebastian Nicolas Fuentes Avalos (auditor de seguridad web).

ANEXO 1. MATRIZ DE RIESGOS EN TI

Esta matriz prioriza **riesgos por verificar**, no hallazgos. Probabilidad e impacto inicial son estimaciones de planificación sujetas a la evidencia. Escala: bajo, medio, alto.

I D	Riesgo / hipótesis del caso	Causa posible	Impacto potencial	Prioridad inicial	Control a verificar / respuesta esperada
R 1	Comunicación o política HTTPS insuficiente	Configuración TLS/HSTS	Exposición de tráfico o degradación de transporte	Alto	TLS fuerte y política de transporte coherente; P02-P03.
R 2	Insertión o ejecución de contenido no deseado	CSP o protección de marcos débil	XSS o clickjacking según contexto	Medio	Política CSP y frame-ancestors/equivalent e efectivos; P03.
R 3	Exposición de token de sesión	Atributos de cookie inadecuados	Robo o uso indebido de sesión, si existe token afectado	Alto	Atributos acordes al uso de la cookie; P04.
R 4	Dependencia cliente vulnerable o recurso alterado	Inventario/actualización o integridad insuficiente	Compromiso del navegador o cadena de suministro	Medio	Versiones verificadas, gestión de dependencias y SRI cuando aplique;



I D	Riesgo / hipótesis del caso	Causa posible	Impacto potencial	Prioridad inicial	Control a verificar / respuesta esperada
					P05.
R 5	Entrada maliciosa en formularios	Validación y codificación insuficientes	Inyección, XSS, procesamiento indebido	Alto	Validación del lado servidor y salida segura; P06.
R 6	Redirección a destino no confiable	Destinos de retorno sin restricción	Phishing con apariencia del dominio	Medio	Lista de permitidos o advertencia; P07.
R 7	Automatización abusiva de formularios	Límites o detección insuficientes	Spam, abuso de recursos o fraude	Medio	Límites y monitoreo proporcionados al riesgo; P08.
R 8	Divulgación de información	Errores detallados, caché o almacenamiento local	Exposición de datos o ayuda a atacantes	Medio	Mensajes genéricos y manejo seguro de datos; P09-P10.

ANEXO 2. MAPEO DE PROCESOS DE TI

Flujo público de referencia: visitante → resolución y conexión TLS → servidor/CDN autorizado → respuesta HTTP y recursos de terceros → navegación → formulario o redirección → servicio de destino. Cada salto a un host distinto se registra como dependencia y se evalúa únicamente dentro de los límites del acta de inicio simulada. El mapa representa el flujo externo que será documentado en los papeles de trabajo.

Proceso de gestión de hallazgos: evidencia → validación manual → calificación → comunicación urgente de riesgos críticos → contradicción técnica → informe → plan de acción → verificación posterior. La entidad conserva la responsabilidad de corregir y aceptar el riesgo residual.

**ANEXO 3. LISTA DE CRITERIOS APLICABLES**

Fuente	Uso en la auditoría	Estado
OWASP ASVS v4.0.3 (es)	Requisitos técnicos identificados en P02-P10; especialmente V3, V5, V7, V8, V9, V11 y V14.	Disponible en el PDF aportado.
OWASP Top 10	Marco general de riesgos mencionado por el caso.	Edición no especificada; no se asignan identificadores concretos.
Criterios internos del caso académico	Contraste de control interno y operación: seguridad de la información, desarrollo seguro, gestión de cambios e incidentes.	Incorporados como supuestos de planificación; no se atribuyen como políticas vigentes de Interbank.
Protección de datos y continuidad operacional	Factores para valorar el impacto y priorizar recomendaciones.	Referencia contextual; el plan no emite una opinión de cumplimiento legal, regulatorio o contractual.

Referencia bibliográfica técnica: OWASP, *Application Security Verification Standard*, versión 4.0.3, edición española suministrada, octubre de 2021, pp. 11-14, 34-35, 39-41, 49-51, 53, 57 y 65-67.

Referencias de costeo: [Junta Nacional de Justicia, Convocatoria CAS N.º 035-2025 — Analista 1 OTIGD](#), remuneración mensual S/ 6,264.19; [SUNAT, Información de personal, diciembre de 2025](#), analista en herramientas de seguridad informática, S/ 5,628.00; [Indeed Perú, Especialista en Ciberseguridad — Lima](#), rango publicado S/ 3,500 a S/ 5,000 mensuales. Las fuentes se usan solo como referentes de mercado y no representan remuneraciones de Interbank ni de los integrantes.

ANEXO 4. INSTRUMENTOS DE RECOLECCIÓN DE EVIDENCIA

**A4.1 Ficha de evidencia**

Campo	Registro requerido
Código	Pxx-Exx, vinculado con procedimiento y objetivo.
Fecha y hora	Fecha, hora y zona horaria de la observación.
Activo	Host, ruta y ambiente autorizado; sin datos personales en la URL archivada.
Condición	Qué se observó y qué requisito se contrastó.
Método	Navegador/herramienta y versión, pasos mínimos de reproducción.
Resultado	Solicitud/respuesta o captura sanitizada; comportamiento esperado y obtenido.
Integridad	Nombre de archivo, hash y custodio; ubicación de resguardo aprobada.
Limitaciones	Variación por CDN, sesión, geografía, hora o controles adaptativos.

A4.2 Guía breve de entrevistas y solicitud documental

Solicitar al propietario técnico: inventario de hosts y rutas permitidas; diagrama de flujo; definición de cookies; política de CSP y HSTS; inventario de componentes de cliente; controles de validación, antifraude y límites; gestión de vulnerabilidades; contacto de incidentes; autorización y reglas de ejecución. Las respuestas orales deben documentarse y, cuando sustenten una conclusión, corroborarse con configuración, procedimiento o registro pertinente.

A4.3 Lista de comprobación de calidad del hallazgo

1. ¿El activo y la ruta estaban dentro del alcance autorizado?
2. ¿La condición se reprodujo de manera controlada o existe evidencia suficiente alternativa?
3. ¿El requisito ASVS aplica a esta función y contexto?
4. ¿Se descartaron caché, CDN, extensión de navegador, cookie no sensible o falso positivo?
5. ¿El impacto y la severidad están sustentados sin extrapolar a sistemas no revisados?



6. ¿Se sanitizaron datos, tokens y detalles que faciliten abuso antes de compartir el informe?

ANEXO 5. MATRIZ DE TRAZABILIDAD

Objetivo	Procedimientos	Evidencia principal	Fuente	Responsable
O1	P01-P03, P10	Acta de alcance, configuración TLS y respuestas HTTP	Portal autorizado y documentación de alcance	Jefe / infraestructura / AppSec
O2	P04-P05, P09	Cookies, inventario de recursos y almacenamiento/caché observado	Navegador y documentación técnica disponible	AppSec
O3	P06-P09	Solicitudes/respuestas benignas, redirecciones y controles de abuso	Formularios y rutas públicas autorizadas; entrevistas	AppSec / jefe
O4	P11-P12	Papeles de trabajo, contradicción, informe y acciones	Evidencias precedentes y respuestas de la entidad	Jefe / supervisor

ANEXO 6. CRONOGRAMA DETALLADO POR ACTIVIDAD Y RESPONSABLE

Semana / días	Actividad	Responsable líder	Producto	Indicador de avance
S1 / 1-2	Inicio, autorización y reglas de ejecución	Jefe	Acta y contactos	Alcance y límites firmados.
S1 / 3-5	Inventario, muestra y programa ajustado	Jefe	Matriz de rutas	Muestra aprobada.
S2 / 6-10	TLS, encabezados, cookies y recursos	Infraestructura / AppSec	Fichas P02-P05, P10	100 % de rutas de muestra inspeccionadas para esos controles.
S3 / 11-15	Formularios, redirecciones, datos y errores	AppSec	Fichas P06-P09	Pruebas del alcance ejecutadas y evidencia registrada.



Semana / días	Actividad	Responsable líder	Producto	Indicador de avance
S4 / 16-17	Validación y comunicación de observaciones	Jefe	Matriz preliminar	Cada observación con criterio y evidencia.
S4 / 18-19	Contradicción y revisión de calidad	Supervisor	Matriz depurada	Respuestas incorporadas o ausencia documentada.
S4 / 20	Entrega y cierre	Jefe	Informe final y acciones	Informe aprobado para entrega.

Indicador global: porcentaje de procedimientos aplicables con resultado y evidencia suficientes. Una restricción de acceso no se convertirá en resultado favorable.